

Descripción de Seguridad Básica

1. Identificación y autenticación:

Cada usuario debe identificarse mediante credenciales (correo y contraseña). El sistema debe consultar la base de datos y validar la existencia de dichas credenciales, para luego proceder con el proceso de autenticación, donde se genera un token de acceso que es validado por la API de autenticación, logrando un inicio de sesión exitoso.

2. Manejo de sesión:

- Las sesiones van a manejarse con un tiempo de expiración para reducir accesos no autorizados, estos tiempos de expiración varían según el rol, por ejemplo, un usuario normal puede estar con su sesión abierta de forma persistente, por ejemplo 7 días, mientras que un funcionario y administrador deberán revalidar sus credenciales tras 30 minutos de inactividad.
- Los funcionarios y administradores acceden a datos personales y médicos de múltiples ciudadanos, por lo que sus sesiones poseen tiempos de expiración más restrictivos para reducir el riesgo de accesos no autorizados en equipos compartidos o desatendidos.
- Si se quiere acceder a funcionalidades protegidas de la aplicación o que requieran un grado de permiso, se debe comprobar que exista una sesión válida y que las credenciales concuerden con el usuario.

3. Manejo de información sensible:

- Para evitar guardar contraseñas reales, estas se guardan en hash para encriptarlas en caso de una filtración.
- Se recopila solo información estrictamente necesaria para el funcionamiento del sistema (no es necesario mostrar todo el historial médico de una persona, por ejemplo, solo historiales de vacunación o alergias).
- Los datos médicos sólo deben ser visualizados por usuarios autorizados por rol, como funcionarios.
- La información sensible no se guarda en logs.

4. Registro de auditoría:

Se lleva un registro de todos los accesos de los funcionarios, con su fecha y horario respectivo.

También se registran las acciones tomadas por personal médico como cambios de disponibilidad y registro de observaciones de vacunación.

5. Comunicación segura:

Toda la comunicación entre clientes, servidores y servicios del sistema se realiza mediante HTTPS/TLS para proteger la información transmitida y evitar la interceptación de datos sensibles.

6. Prevención de ataques:

Para evitar ataques de fuerza bruta se implementa un límite de 3 intentos por minuto y se registra para buscar comportamiento sospechoso.

Se implementa una validación de entrada para aceptar solo ciertos tipos de caracteres y formatos definidos previamente para evitar ataques de inyección de código externo.

Para lidiar con el escalamiento de privilegios en el sistema se implementará un control de acceso basado en roles estrictos donde cada solicitud protegida deberá verificar la validez del inicio de sesión y los permisos de rol que lo solicita.

7. Distinción explícita de roles:

Usuario: Corresponde a las personas naturales o ciudadanos que usen el sistema para realizar el proceso de vacunación. Como permisos tendría:

- Capacidad de registrarse e iniciar sesión en el sistema.
- Consultar historial de vacunación.
- Gestionar su propia cita para vacunación (solicitarla, modificarla o cancelarla).
- Consultar campañas de vacunación vigentes.
- Ver información de centros de vacunación.

Funcionario de salud: El funcionario de salud cumple un rol operativo, atendiendo al usuario y registrando las vacunaciones realizadas, dejando constancia de las fechas y el personal responsable de la vacunación. Se consideran los siguientes permisos bajo su responsabilidad:

- Capacidad de iniciar sesión en el sistema.
- Consultar historial de vacunación.
- Consultar las citas de los usuarios (solicitar, modificar y validar).
- Consultar campaña de vacunación vigente.
- Consultar punto de vacunación.
- Registrar vacunación realizada.
- Marcar citas de usuarios como completadas.
- Marcar citas de usuarios como no asistidas.

Administrador: Corresponde a un encargado de registrar los centros de vacunación y campañas en el sistema, además de asistir en la gestión de las cuentas de cada rol. Entre los permisos que tendría se consideran:

- Capacidad de iniciar sesión en el sistema.
- Crear y gestionar los centros de vacunación en el sistema, incluyendo cuentas para los funcionarios de cada uno.
- Capacidad de manejar los permisos de funcionario.
- Crear y modificar las campañas de vacunación, con sus fechas, alcance y grupos objetivo.
- Asociar los centros con determinadas campañas.
- Consultar el estado de una persona determinada según sea solicitado.
- Consultar el avance general de las campañas de vacunación.
- Consultar y modificar la disponibilidad de los centros de vacunación.
- Modificar o cancelar citas de los usuarios en caso de haber problemas de disponibilidad.

8. Control de acceso por rol

Cada vez que el sistema recibe una petición para ejecutar un proceso, valida que el rol de la sesión activa posea los permisos correspondientes para realizar la acción.

Acción a realizar.	Usuario	Funcionario	Administrador
Ver campañas.	SI	SI	SI
Gestionar cita propia.	SI	NO	NO
Ver historial médico propio.	SI	NO	NO
Ver historial médico pacientes.	NO	SI	SI
Registrar vacunas.	NO	SI	NO
Gestionar puntos de vacunación.	NO	NO	SI
Gestionar campañas.	NO	NO	SI

9. Protección de operaciones según el rol autenticado

El sistema protege sus funcionalidades mediante un mecanismo de autorización basado en roles. Una vez autenticado, cada usuario puede acceder únicamente a las operaciones permitidas para su rol.

Antes de permitir realizar alguna acción, se debe verificar la identidad del usuario y si tiene los permisos necesarios para la ejecución, en caso de no tenerlos se deniega el acceso.

Así, los usuarios normales solo podrían gestionar sus propias citas y su información de vacunación y no la de otros usuarios. Los administradores podrían registrar y editar información relacionada con las campañas de vacunación.